

Security+ 1.4 · Key Exchange

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4 — Key Exchange (3:39)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Diffie-Hellman allows two parties to derive the same secret key by exchanging only public values, without ever transmitting the key itself. Modern TLS uses ECDHE (ephemeral Diffie-Hellman) to generate a new key per session, providing Perfect Forward Secrecy (PFS): even if the private key is compromised later, past sessions remain secure.

High-Yield Core Concepts Tested on Exam

- Diffie-Hellman exchanges public values to derive a private key; the key never travels over the network
- Ephemeral keys (ECDHE) generate a new key per session, enabling Perfect Forward Secrecy
- PFS ensures that past sessions cannot be decrypted if the private key is later compromised
- ECDHE is the preferred key exchange in modern TLS
- Diffie-Hellman does not provide authentication by itself; it must be combined with signatures

Exam Tips & Classic Scenarios

- 'requires parties to derive a shared secret over an untrusted channel' = Diffie-Hellman
- 'protects past sessions even if key leaks' = Perfect Forward Secrecy
- Look for 'ephemeral' to indicate PFS

Typical Exam Scenario: Two systems need to establish encrypted communication without exchanging a key beforehand. This is achieved using Diffie-Hellman key exchange.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Key Exchange)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Exchanging a secret key over a public channel WITHOUT sending it directly uses:

- A)** Diffie-Hellman
- B)** AES
- C)** SHA-256
- D)** Base64

2. Which type of encryption uses public and private key pairs?

- A)** Hashing
- B)** Symmetric encryption
- C)** Asymmetric encryption
- D)** Steganography

3. AES is an example of encryption:

- A)** Symmetric (same key encrypts and decrypts)
- B)** Asymmetric (key pair)
- C)** One-way hash
- D)** Base64 encoding

4. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'DH exchanges public values and derives a private key — the key NEVER travels'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: DH exchanges public values and derives a private key — the key NEVER travels...

5. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Ephemeral (ECDHE) = key per session — PFS'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Ephemeral (ECDHE) = key per session — PFS...

6. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'PFS = if the private key leaks, PAST sessions are not decrypted'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: PFS = if the private key leaks, PAST sessions are not decrypted.

7. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'protects past sessions even if key leaks' = Perfect Forward Secrecy'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'protects past sessions even if key leaks' = Perfect Forward Secrecy...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Typical scenario: 'two systems establish encryption without exchanging a key' → Diffie-Hellman.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Typical scenario: 'two systems establish encryption without exchanging a key' → Diffie-Hellman...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Key Exchange): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'DH exchanges public values and derives a private key — the key NEVER travels'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: DH exchanges public values and derives a private key — the key NEVER travels...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Diffie-Hellman.

✓ **Why it is correct:** The Diffie-Hellman (DH) algorithm and its ephemeral variants (DHE, ECDHE) allow two parties to establish a shared secret key over an insecure public channel without ever transmitting the key directly. Each party generates a key pair (private and public), exchanges public keys, and using their private key and the other party's public key, computes the same secret. An observer who intercepts the public keys cannot derive the secret due to the difficulty of the discrete logarithm problem (or elliptic curve discrete logarithm). This secret is then used to derive symmetric session keys, ensuring confidentiality even on untrusted networks.

✗ **Why the others are wrong:**

- **AES:** AES (Advanced Encryption Standard) is a symmetric block cipher used to encrypt bulk data with a pre-shared secret key. It does not solve the problem of establishing that initial secret key over a public channel; if the AES key were sent directly, an interceptor would capture it and could decrypt all communication. AES is the end recipient of the secret generated by Diffie-Hellman, not the exchange mechanism itself.
- **SHA-256:** SHA-256 is a cryptographic hash function that produces a 256-bit digest from an input, used for integrity verification and digital signatures. It is not a key agreement protocol and does not generate shared secrets between parties. Applying SHA-256 to a key does not make it secret; the hash is one-way, but it does not prevent an attacker who sees the original input from discovering the key. Therefore, SHA-256 does not replace Diffie-Hellman in secure key exchange.
- **Base64:** Base64 is an encoding of binary data into ASCII text, used to transport information in text-based protocols (such as MIME email). It is not encryption or key agreement; it is a reversible transformation without a key. Anyone can trivially decode Base64. Using Base64 to 'exchange a secret key' would mean sending it in clear text disguised, completely violating the requirement not to transmit it directly and exposing the secret to any interceptor.

2) C — Asymmetric encryption.

✓ **Why it is correct:** The correct answer is 'Asymmetric encryption'. Asymmetric encryption, also called public-key cryptography, uses a mathematically related key pair: a public key, which can be freely distributed, and a private key, kept secret by the owner. The public key is used to encrypt data or verify digital signatures, while the private key is used to decrypt or sign. Examples include RSA, ECC, and Diffie-Hellman. CompTIA Security+ requires understanding that asymmetry solves the key distribution problem and provides confidentiality, integrity, authentication, and non-repudiation.

✗ **Why the others are wrong:**

- **Hashing:** Hashing is a one-way cryptographic function that transforms an input of variable length into a fixed-length output (digest). It does not use keys and is not used to encrypt/decrypt data, but rather to verify integrity. This option is incorrect because hashing does not involve key pairs and does not provide confidentiality.
- **Symmetric encryption:** Symmetric encryption uses a single shared secret key between parties to encrypt and decrypt. Examples: AES, DES, 3DES. Although efficient, it does not use a public and private key pair. This option is incorrect because it describes the single-key model, not the asymmetric model.
- **Steganography:** Steganography is the art of hiding information within other files (images, audio, video) so that the existence of the message goes unnoticed. It does not involve public or private key cryptography. This option is incorrect because it is not a key-based cryptographic method, but rather a concealment technique.

3) A — Symmetric (same key encrypts and decrypts).

✓ **Why it's correct:** The correct answer is 'Symmetric (same key encrypts and decrypts)'. AES (Advanced Encryption Standard) is a symmetric encryption algorithm, meaning the same key is used to both encrypt and decrypt data. It is a widely adopted standard, with key sizes of 128, 192, or 256 bits, and is considered secure and efficient. CompTIA Security+ SY0-701, in the Security Implementation domain (3.3), lists AES as an example of symmetric encryption. The question asks for the correct classification of AES, which is symmetric.

✗ **Why the others are wrong:**

- *Asymmetric (key pair):* Asymmetric encryption uses a key pair: a public key to encrypt and a private key to decrypt (or vice versa for signatures). Examples include RSA, ECC, and Diffie-Hellman. AES is not asymmetric; it uses a single shared secret key. Therefore, this option is incorrect.
- *One-way hash:* Cryptographic hash functions, such as SHA-256 and MD5, are one-way: they transform input data into a fixed-size output, with no possibility of reversal. They do not use a key and serve for integrity, not confidentiality. AES is a reversible cipher algorithm with a key, not a hash. Therefore, this option is incorrect.
- *Base64 encoding:* Base64 is an encoding that represents binary data in ASCII format, used to transmit data in environments that only support text. It is not encryption, as it does not use a key and is easily reversible. AES is a cryptographic algorithm, not an encoding. Therefore, this option is incorrect.

4) D — Implement the corresponding solution: DH exchanges public values and derives a private key — the key NEVER travels....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): DH exchanges public values and derives a private key — the key NEVER travels. Diffie-Hellman allows two parties to establish a shared secret over an insecure channel without transmitting the key itself.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: Ephemeral (ECDHE) = key per session — PFS....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): Ephemeral (ECDHE) = key per session — PFS.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) D — Implement the corresponding solution: PFS = if the private key leaks, PAST sessions are not decrypted..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): PFS = if the private key leaks, PAST sessions are not decrypted. Perfect Forward Secrecy (PFS) ensures that session keys are not compromised even if the long-term private key is compromised; the appropriate control is to implement the corresponding solution, such as using ephemeral Diffie-Hellman key exchange.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

7) A — Implement the corresponding solution: 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): 'requires parties to derive a shared secret over untrusted channel' = Diffie-Hellman. Diffie-Hellman is a key exchange protocol that allows two parties to establish a shared secret over an insecure channel without prior shared secrets.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: 'protects past sessions even if key leaks' = Perfect Forward Secrecy....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): 'protects past sessions even if key leaks' = Perfect Forward Secrecy. Perfect Forward Secrecy (PFS) ensures that a compromise of long-term keys does not compromise past session keys, thus protecting past communications.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Typical scenario: 'two systems establish encryption without exchanging a key' → Diffie-Hellman....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): Typical scenario: 'two systems establish encryption without exchanging a key' → Diffie-Hellman. Diffie-Hellman allows two parties to agree on a shared secret key over an insecure channel without ever transmitting the key itself. This is essential for establishing secure communications in protocols like TLS, SSH, and IPsec. The security relies on the computational difficulty of the discrete logarithm problem.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: DH exchanges public values and derives a private key — the key NEVER travels....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Key Exchange): DH exchanges public values and derives a private key — the key NEVER travels. Diffie-Hellman (DH) is a key exchange protocol that allows two parties to establish a shared secret over an insecure channel without transmitting the secret itself. Each party generates a private key and computes a public key; they exchange public keys and independently compute the same shared secret. The private keys are never transmitted. This is fundamental to protocols like TLS, SSH, and IPsec.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

